Security architecture and control posture

A concise brief for chief security officers and information-security heads. Code-level control presence is not production assurance.

Trust boundaries

Browser or callback → authenticated/signed identity → organization and subject authorization → approved domain evidence → bounded AI or registered tool → output validation / current approval gates → optional governed external effect → protected audit. Read-only policy and explanation paths do not authorize operational writes.

Identity and authority | SEC / COM

Tenant/case isolation; group, field and tool scope; expiring grants; registered agent versions; independent specialist authority. Signed callbacks, trusted sender/case binding, recipient authorization, deduplication and communication caps constrain ingress and egress.

Privacy and document evidence | PRI / DOC

Sensitive policy and live disclosure gates; conservative opaque-content handling; scoped minimization/masking; holds and separate lifecycles. Private upload/quarantine gates remain independent from signed issuer verification. Vault requires employee consent, exact version binding and all employer-required checks.

Responsible-AI controls | AI

Approved extract selection, exact quotation validation and fresh citation access; structured decisions and untrusted-content fences; sensitive-topic human handoff; no adverse employment decision from model output alone. Budgets: 24,000 conservative input-token upper bound using UTF-8 bytes, 16,000 output-token allowance, 40,000 combined bound; oversize is rejected, not silently truncated. Case explanations are read-only and evidence-grounded.

Scope and configuration limits

Live policy approvals, scanner and issuer coverage, professional authority, channel allowlists and external audit protection are client-specific prerequisites. Verify provider data terms and deployment posture separately. Defence-in-depth does not imply zero leakage, perfect answers or bias-free decisions.

Status: implemented control ≠ configured service ≠ measured assurance. The companion register separates all three from roadmap and unverified deployment facts.

Harness, metrics and residual assurance

Assess enforceable boundaries, reproducible evidence and defined measurements—not model confidence or a single responsible-AI score.

Runtime harness | RUN / AUD

Tenant/subject/actor/executor-bound context; fresh dispatch gates; checkpoint and owner fencing; durable effects with stable operation identity. Ambiguous non-idempotent effects stop for reconciliation. Metadata-only history has live disclosure permissions and hold-aware approved pruning. External audit receipts/drills and the selected-tenant regulated startup guard require configuration.

Testing harness | TST

13 catalogued communication guardrails with intervention records; controlled synthetic security drills; UAT evidence distinctions; regression and browser checks. Inventory pointers show where checks exist, not that today's suite passed. Simulated exchange, successful delivery and passed fixture initialization are not verified business outcomes.

Available measurements | MET-01–08

Guardrail events, drill steps, context traces and request budgets; derived case/approval review, autonomy and current exception rates. Event recording is bounded. Request bytes/allowance are not actual token usage. The main Analytics summary does not establish SLA performance or average resolution time. No live numeric results are asserted in this pack.

Additional assurance | MET-09–12 / MAP

Complete reviewed correctness/support and abstention benchmarks; governed fairness tests and independent challenges; scoped privacy-leakage and recovery evaluations; consolidated compliance/provider evidence. Quality and fairness work is separately underway, not treated as a shipped scorecard.

Security acceptance evidence | DEP

Require scoped access and authority evidence; approved processing/retention; current scanner/issuer and independent audit receipts; relevant test dates/results; incident ownership. Separately verify MFA/SSO posture, encryption/key management, residency/transfers, AI-provider retention/training, SIEM/response, backup RTO/RPO and claimed certifications.

Evidence scope: source/test pointers and defined metrics—not live values, a fresh test run or an independent certification. Detailed limitations: companion control register.